

Laboratório SOC Analyst N1 — Investigação de PowerShell Suspeito

Cenário

Sou analista SOC Nível 1 da empresa fictícia **BlueFinance**.

Durante meu turno, o SIEM gerou um alerta relacionado à execução suspeita de PowerShell em uma máquina de usuário.

O alerta chamou atenção porque o comando estava:

- codificado em Base64
- usando parâmetro -EncodedCommand
- executado via PowerShell oculto

Meu objetivo era descobrir:

- se era atividade legítima
- o que o comando fazia
- se houve comprometimento
- quais IOC precisavam ser escalados

Alerta recebido

Alert: Suspicious PowerShell Execution

Host: FIN-WKS-044

User: m.rocha

Severity: High

CommandLine:

powershell.exe -nop -w hidden -EncodedCommand
SQBIAGwAbABvACAaVwBvAHIAbABkAA==

Time:

2026-05-12 14:33:21

Primeira análise

Assim que vi o alerta, alguns parâmetros me chamaram atenção:

Parâmetro	Motivo
-nop	evita carregamento de perfil
-w hidden	oculta janela
-EncodedCommand	dificulta análise
Base64	técnica comum em malware

Minha primeira hipótese foi:

- possível execução maliciosa via PowerShell

Investigando no Splunk

Comecei pesquisando os eventos relacionados ao host.

Pesquisa inicial no Splunk

index=windows host="FIN-WKS-044" powershell.exe

Resultado:

EventCode=4688

NewProcessName=C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

CommandLine:

powershell.exe -nop -w hidden -EncodedCommand
SQBIAGwAbABvACAAVwBvAHIAbABkAA==

Refinando a investigação

Resolvi procurar execuções semelhantes em outros hosts.

Pesquisa Splunk — procurar uso de EncodedCommand

index=windows powershell.exe EncodedCommand

Percebi que apenas aquela máquina apresentava o comportamento.

Se eu estivesse investigando no Microsoft Sentinel (KQL) faria assim:

```
DeviceProcessEvents  
| where FileName == "powershell.exe"  
| where ProcessCommandLine contains "EncodedCommand"  
| project Timestamp, DeviceName, AccountName, ProcessCommandLine
```

Resultado:

Timestamp: 2026-05-12 14:33:21
DeviceName: FIN-WKS-044
AccountName: m.rocha

Decodificando o Base64

Nesse momento precisei descobrir:

- o que realmente estava sendo executado

O trecho Base64 era:

SQBIAGwAbABvACAAVwBvAHIAbABkAA==

Após decodificar, obtive:

Hello World

Mudança na investigação

Após a decodificação percebi que:

- o comando não era malicioso
- era apenas um teste simples em PowerShell

Mesmo assim, continuei investigando para validar contexto.

Verificando atividade relacionada

Procurei:

- downloads
- conexões externas
- criação de arquivos
- persistência
- execução de scripts adicionais

Pesquisa Splunk — conexões de rede

```
index=windows host="FIN-WKS-044"
```

```
(CommandLine="*Invoke-WebRequest*" OR CommandLine="*DownloadString*")
```

Nenhum resultado encontrado.

Pesquisa KQL — conexões suspeitas

```
DeviceNetworkEvents
```

```
| where DeviceName == "FIN-WKS-044"
```

```
| where InitiatingProcessFileName == "powershell.exe"
```

```
| project Timestamp, RemoteIP, RemoteUrl
```

Nenhuma conexão externa suspeita foi identificada.

Investigando o usuário

Entrei em contato com o usuário responsável pela máquina.

O usuário informou que:

- estava estudando PowerShell
- realizou testes locais
- copiou exemplos da internet

Conclusão da investigação

Após análise:

- não identifiquei evidências de malware
- não houve download de payload
- não houve persistência
- não houve comunicação externa

Classifiquei o alerta como:

False Positive / Administrative Activity

IOC avaliados

Mesmo sendo falso positivo, documentei:

IOC	Status
uso de EncodedCommand	identificado
PowerShell oculto	identificado
Base64	identificado
conexões externas	não encontradas

Relatório SOC N1

Foi identificado alerta relacionado à execução de PowerShell com uso de EncodedCommand na estação FIN-WKS-044.

Durante a investigação foi realizada análise do comando codificado em Base64.

O conteúdo decodificado retornou:
"Hello World"

Não foram identificadas:

- conexões externas
- downloads
- persistência
- execução de payload

Usuário confirmou atividade de estudo/teste relacionada a PowerShell.

Alerta classificado como falso positivo.

O que aprendi nesse laboratório

- Como investigar PowerShell suspeito
- Como pesquisar no Splunk
- Como pesquisar em KQL
- Como analisar Base64
- Como diferenciar malware de atividade legítima
- Como validar contexto com usuário



Autor: Paulo Cesar
Formado em Segurança da informação
[linkedin.com/in/paulo-cesar-security](https://www.linkedin.com/in/paulo-cesar-security)